Threat evolution in Q3 2017

GROUP-IB
GLOBAL CYBER SECURITY COMPANY

Table of contents

Introduction 3
Executive summary 4
Forecasts for Q4 2017 8
Financially motivated APT 9
Financial threats 12
Malware for Android 13
Malware for PC 17
Attacks on ATM and POS terminals 22
Other attacks and tools 24
State-sponsored APT 26
Data leakage 33
Hacktivism 36

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on the USA, Canada, Europe, Russia and Australia. This document also provides a comprehensive description of threats to governments, including hacktivists' attacks, targeted attacks supported by government and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring the most secretive underground hacker forums and accumulating information on new trends, threats and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

The third quarter of 2017 was very eventful for the information security industry:

- Marcus Hutchins, the alleged author of the Kronos banking Trojan, was detained;
- Europol shut down two of the largest illegal marketplaces in DarkNet - AlphaBay and Hansa;
- New vulnerabilities - CVE-2017-8759 (SOAP WDSL) and BlueBorn (Bluetooth vulnerabilities) – were disclosed;
- The Cobalt group continued to attack financial institutions around the world;
- One of the biggest data breaches ever occurred in Equifax, one of the largest credit reporting agencies in the United States;
- More security incidents will be covered through this report.

Executive summary

Targeted attacks on the financial sector

- The Cobalt group continued to evolve. They started using a new JavaScript backdoor designed to perform reconnaissance and more effective exploits. The group also improved the quality of phishing emails employed.
- Recent malicious email campaigns showed a new trend: English-speaking companies have become the key target. However, banks in Russian-speaking countries are still being attacked.
- The Fin7 group conducted attacks using a new JavaScript backdoor dubbed Bateleur;
- The MoneyTaker group, which has ties to Fin7, continues to attack banks in North America. For a while they suspended their activity, but at the end of August the group returned to attacks.
- Specialists detected an attack on financial institutions using a remote access tool dubbed NetWire. The involvement of a certain group has not yet been identified.
- Spear-phishing emails containing an exploit that had been previously used by the hacker group APT28 were sent to Russian-speaking banks.

Financial threats

- RTM and Buhtrap Trojans actively attacked banks in Russia and the CIS. Cybercriminals distributed the malware through compromised legitimate websites for accountants and lawyers.
- The following mobile Trojans were active in the CIS countries: Asacub, Gugi (Limebot), Agent.sx, FlexNet, Agent.BID.
- The following Trojans for Android appeared in Q3 2017: Easy bot, Exobot 2.0, CryEye, Asacub (previously sold only privately). Also, an infamous criminal hiding under the name GanjaMan (who restored his banned account on underground resources) began to sell his new product - the "Cannabis" bot.
- Clients of European and Australian banks continued to be attacked by Marcher and Alien-bot.
- A new version of the Trickbot banking Trojan appeared. It now comes with self-replicating capabilities and the ability to attack browsers and Outlook. Developers also added the functionality to steal money from Coinbase accounts.
- The activity of the Ramnit banking Trojan has increased. It also now has the self-distribution mechanism.
- In previous reports, we informed our clients that we had stopped observing activity of the Kronos banking Trojan. Now it is clear why: its alleged author Marcus Hutchins was arrested in early August. This man managed to stop the spread of the WannaCry attack in May this year. At the moment, legal proceedings against him are ongoing.
- A Russian citizen Mark Vartanian was sentenced to five years' imprisonment in the USA for participating in the development and maintenance of Citadel malware. Attacks using Citadel are no longer observed in the wild.
- During the reporting period, Group-IB specialists detected attacks on banks in Europe, the US, Canada and Australia using Tinba, Zeus, ZeusVM, Qbot banking Trojans.
- Dridex malware was spread through a phishing attack on customers of Xero – a New Zealand company that provides cloud-based accounting solutions for small and medium-sized businesses. Malicious emails contained a JavaScript file that loaded Dridex onto the machine.
- We also observed attacks using the Emotet Trojan, which has the functionality to steal personal data of victims, and deliver additional malware. In July, an Emotet version with self-propagation capabilities was detected. Security specialists at Sophos believe that Emotet was used to deliver Dridex and Qbot Trojans, because it was detected along with these malicious programs on the infected machines.
- TrickBot and Atmos continued to attack French and Polish banks.

- The Gozi banking Trojan (aka ISFB) is attacking Japan, while its purportedly modified version is targeting Australia.
- Group-IB specialists did not detect any activity of the Gootkit and Qadars banking Trojans.
- A malicious program for Wincor ATMs called "Cutlet" began to be actively sold on underground resources. This tool is designed to make ATM dispense notes until machines are empty.
- On underground resources, criminals started selling a malicious program for POS terminals dubbed Sisyphus.
- Incidents using Blackbox devices for thefts from ATMs were identified in Ukraine, Romania, Switzerland, and Great Britain during the reporting period.
- LockPOS Trojan attacked POS terminals in the US, Canada, and Brazil.
- Researchers at IOActive discovered two vulnerabilities in Opteva ATMs (Physical and Authentication Bypass) that, when combined, may allow an unauthorized user to vend notes from the device.
- Specialists managed to identify the identity of the alleged developer of a 0day exploit for the recently patched CVE-2017-8759 vulnerability. He turned out to be a Russian-speaking hacker, who informed that he was developing other exploits.
- A threat actor monickered Links was reported to have attacked Fortune 500 companies by infecting routers with the RouteX malware.

Threats to blockchain and cryptocurrencies

The number of phishing attacks on crypto-currency platforms is growing. For example, one blockhain startup alone, Enigma, lost over $400,000 USD ahead of the ICO. The focus of hackers using such traditional hacking tools as the Cerber ransomware is also being shifted to stealing cryptocurrency. The Trickbot banking Trojan no longer just targets banking portals, but also the Coinbase exchange with a new functionality adopted.

In late August, Group-IB specialists detected a phishing page of the crypto-currency hedge fund Numerai (US), where the Ethereum cryptocurrency may be exchanged for the fund's own currency - Numeraire tokens. The phishing page was distributed via the Slack messenger, while the criminals pretended to be the hedge fund employees. The attackers proposed to buy Numeraire tokens with payment in cryptocurrency, lured victims into providing them private keys and withdrew all the money from users' accounts. The same fraudsters created copies of websites belonging to 7 other crypto-currency projects. In August they obtained private keys and emptied almost 350 wallets. The total amount of stolen money was over $1.4 million. Resources are mostly hacked during an ICO (Initial Coin Offering).

FireEye specialists also warned that the North Korean threat actors Lazarus started targeting cryptocurrency exchanges. State-sponsored actors are reported to be seeking to steal bitcoin and other virtual currencies; specialists tracked their attacks on at least three South Korean cryptocurrency exchanges.

Data leaks

- Hackers stole sensitive personal information on as many as 143 million U.S. consumers from the Equifax credit reporting firm. This breach is considered one of the biggest data leaks over the past few years.
- Global tax and auditing firm Deloitte has confirmed the company suffered a cyber-attack that resulted in the theft of confidential information, including private emails and documents of clients. Attackers were able to penetrate the global mail server Deloitte under administrator login that, in theory, gave them privileged, unrestricted “access to all areas”, including correspondence of Deloitte's 244,000 staff with their clients.
- In July, UniCredit Bank announced a data breach, which resulted in cybercriminals being able to steal data on 400,000 loan applicants.

- A critical API vulnerability in Instagram enabled attackers to access personal details of more than 6 million users.
- Taringa, a Latin American social network confirmed a data breach that exposed nearly every record in its 28 million registered user base, including usernames, email addresses, and hashed passwords.
- The OurMine hacker group breached the popular video streaming service Vevo and leaked about 3.12 TB worth of internal files.
- WikiLeaks exposed new CIA hacking tools called Achilles, Aeris and SeaPea for Mac and Linux, as well as an Android hacking tool “HighRise”. They also published documents on the collaboration between the US Intelligence agency and the CIA contractor Raytheon Blackbird Technologies.
- Shadow Brokers launched a subscription service for new hacking tools and exploits from the NSA archives. The cost of service is growing. The Shadow Brokers' dump of exploits in August contained the UNITEDRAKE implant designed to collect data on Windows devices.
- A database of Alaska voters appeared to have been inadvertently exposed.
- In August, the Securities and Exchange Commission said in a statement that it was still investigating the breach of its corporate filing system that occurred in 2016.

Threats to the Government sector

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. In Q3 2017 the following active APT campaigns were detected:

- Current geopolitical disputes between the US and North Korea, India and China, Pakistan and India, Russia and Ukraine are being accompanied by an increase in cyber espionage campaigns. We believe that it is not just the number of attacks that is rising (as in the case of North Korea), but the new conflicts have led to changes in the attackers' goals.
- State-backed hackers are testing new, more dangerous attack tools and methods resulting not only in the theft of confidential information, but also in the malfunction of corporate networks belonging to companies and government entities.
- The North Korean group Lazarus was behind a recent cyber espionage campaign against Pentagon contractors.
- In early August, it was reported that hackers had broken into the system of EirGrid, a state-owned company that manages and operates the electricity transmission grid across the island of Ireland.
- Group-IB specialists detected fraudulent emails targeting Russian government institutions using FinSpy spyware.
- The Turla group conducted new campaigns against governments, their officials and diplomats in Europe as well as in countries of the former Soviet Union.
- The APT28 group attacked hotel guests in Europe and the Middle East.
- The energy sector in Europe and North America is being targeted by Dragonfly attackers.
- Spring Dragon cybercriminals are attacking government organizations and political parties, educational institutions, as well as telecommunications companies around the South China Sea, including Taiwan, Indonesia, Vietnam, the Philippines, Hong Kong, Malaysia and Thailand.
- DragonOK targets Cambodian government organizations.
- The DarkHotel group focused on attacks against government employees in North Korea.
- In addition, unknown hackers used a backdoor named ShadowPad, which was built into the popular server software NetSarang to compromise data of large companies.
- Also, a hacker originating from Nigeria attacked companies of the energy, mining and infrastructure companies using Netwire RAT.

Hacktivism

- In Q3 2017, hacktivists conducted over 2,600 attacks on more than 3,600 unique online resources. Over 2,400 attacks detected were “page replacement” (Defacement), more than 200 attacks were DDoS attacks (Denial of Service). In these attacks hacktivists targeted government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Thailand, Indonesia, Brazil, Vietnam, Peru, Mexico, Turkey, Myanmar, Russia, Italy, and India.

Forecasts for Q4 2017

- The Cobalt group will become even more effective due to the improvements in their tools: the Trojan and phishing emails. Thy may shift their focus to English-speaking companies, where they will most likely attack card processing systems.
- The FIN7 group will continue to conduct targeting attacks aimed at collecting bank card data.
- The MoneyTaker group can return to attacks on banks in Russia, as they already did in Q4 2016. However, their key goal will remain small banks in the US and, perhaps, in England.
- Due to the start of sales of a malicious software for ATMs named Cutlet, the number of successful attacks on ATMs can grow.
- We expect an increase in thefts using mobile banking Trojans due to the fact that they are being sold on a massive scale, while more and more new Trojans appear.
- The most dangerous banking Trojans for Windows will be Tinba, Dridex, TinyNuke (and its versions), Zeus, TrickBot, Emotet.
- Marcher and Alien-bot mobile Trojans will attack bank customers in Europe and Australia.
- Limebot, Asacub, Agent.BID will remain the most dangerous mobile threats for clients of Russian banks.
- To steal money from Windows users in Russia, RTM and Buhtrap programs will be used, and the most dangerous method of theft will be auto-fill attacks performed through the 1C system.
- Criminals will use new tools exposed by Shadow Brokers by subscription, in particular, the UNITEDRAKE spyware from the August dump. It is also expected that targeted attacks will be difficult to detect due to the use of advanced expensive tools.
- After recent attacks by state-backed hackers using ransomware with self-propagating capabilities have demonstrated their effectiveness, other pro-state hackers are likely to start developing similar tools. This will lead to new attacks. Since the NotPetya attack targeted enterprises and organizations in Ukraine, countermeasures can be taken – by conducting attacks focused on government and financial institutions.
- We expect an increase in the number of targeted attacks before the end of the year. That said, some groups will change their goals in order to collect intelligence data more effectively, for example, they will attack the infrastructure of hotels, where participants of political events stay.
- Attacks on cryptocurrency services will become regular. Due to the huge flow of investments into crypto-currency services, as well as the gradual legalization of cryptocurrencies in different countries, the number of cyber-attacks on blockchain startups and the amount of respective damage will grow, according to our forecasts.
- We expect new phishing attacks on blockchain services; modules designed to steal money from cryptocurrency wallets will be added to the existing malicious programs.
- Groups and individual hackers conducting targeted attacks on banks or thefts from bank customers can temporarily switch to cryptocurrency services, using proven tactics of attacks on banks and the same tools.
- Due to the shutdown of the popular underground trading platforms AlphaBay and Hansa, attackers will start switching to some other services (one of them, perhaps, DreamMarket) or will create a new one.

Financially motivated APT

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks on banks from the Cobalt hacker group	Russia, Kazakhstan, Ukraine	CP-1438-26 – CP-1438-31	June 2016

In Q3 2017, the tactics of the Cobalt group changed as follows:

- The criminals began using a new JavaScript backdoor designed to perform reconnaissance of the victim's computer and assess the feasibility of further attacks. Group-IB staff thoroughly analyzed this tool.
- Attackers used phishing emails to launch this backdoor on the target machine. This program performs initial data collection and sends it to the C&C server. In response, it receives commands (PowerShell and JavaScript scripts) which are executed by the malicious program.
- Using access to the VPN, the criminals examined the network map and installed the Cobalt Strike malware using the ETERNALBLUE exploit leveraging the CVE-2017-0143 vulnerability. In the same way, access to ATMs was obtained. After that, they downloaded a specific software to them that had been used in their previous attacks, which allowed criminals to control cash dispensers.
- They also used a new exploit for the CVE-2017-8759 vulnerability, which was patched only on September 12.
- The criminals began using decoy documents, which we had not observed in their previous attacks. These documents have real contents and are opened during the attack in order to lull the victim into a false sense of security.
- It is also worth noting that criminals began to expand the geography of attacks: they send English-language malicious messages to banks in the US and Europe.
- Currently, their main target is card processing systems in banks, but they also continue to attack ATMs and payment gateways.

APT name	Regions attacked	Related notifications	Operation start
Targeted attack using an exploit of the APT28 hacker group	Russia, Ukraine, Kazakhstan	CP-1601	2017

On August 16, 2017 malicious emails were sent to banks in Ukraine, Kazakhstan and Russia. A distinctive feature of this campaign is the use of an exploit that is attributed to a state-sponsored hacker group dubbed APT28, as well as a new backdoor employed. Emails employed and specific features of the campaign indicate that the Cobalt group may have been behind the attack. However, currently we do not have any confirmation of this hypothesis.

This campaign leveraged the CVE-2017-0262 and CVE-2017-0263 vulnerabilities using exploits adjusted to attack financial institutions. It’s worth reiterating that these vulnerabilities were patched in May. Approximately at the same time information about the exploits appeared.

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks using NetWire RAT	Canada, India, Global	CP-1609	September 2017

On September 11, Group-IB specialists discovered a Microsoft Word document named "Bank Transaction Codes.doc", which appeared to be an exploit for CVE-2017-0199. The vulnerability allows cybercriminals to download the NetWire remote control tool on the victim’s machine. Its capabilities include collecting and sending data, providing remote access to the infected system, downloading and executing files from the network. We believe that this is a targeted attack against the finance industry. Specialists identified that the document had been sent to Canada and India and most likely the list of targeted countries is more extensive.

APT name	Regions attacked	Operation start
FIN7	USA	2015

A new attack of the FIN7 hacker group, discovered in the summer of 2017, targeted U.S.-based chain restaurants. Security specialists uncovered that the attack had been conducted using a new tool backdoor called Bateleur.

To launch the attacks, hackers sent phishing emails to restaurant employees, which purported to be information on a previously discussed check. The emails were sent from Outlook.com and Gmail.com accounts. The attached document named “check.doc” claimed that the document was encrypted by Outlook Protect Service /Google Documents Protect Service. After the document was opened, the macro ran, extracted JavaScript code and saved it in the created debug.txt file.

In the first step, the macro creates a scheduled task whose purpose is to execute debug.txt as a JScript. The macro then sleeps for 3 seconds, after which it runs the scheduled task. Finally, the macro sleeps for 10 seconds then deletes the malicious scheduled task. The combined effect of these commands is to run Bateleur on the infected system in a roundabout manner in an attempt to evade detection. The backdoor also has a number of additional features to hide its including anti-sandbox functionality and anti-analysis (obfuscation) features.

Bateleur capabilities include retrieval of infected system information, listing of running processes, overwriting/deleting the debug.txt file, loading of EXEs and DLLs, execution of custom commands and PowerShell scripts, and obtaining user credentials.

Bateleur used an HTTP POST request to receive instructions from the C&C server. After each command was executed, the backdoor sent the "OK" status or the result of the command execution to C&C.

The FIN7 group was first discovered in late 2015. They have been known for their attacks on financial institutions.

Financial threats

GROUP IB

GLOBAL CYBER SECURITY COMPANY

Malware for Android

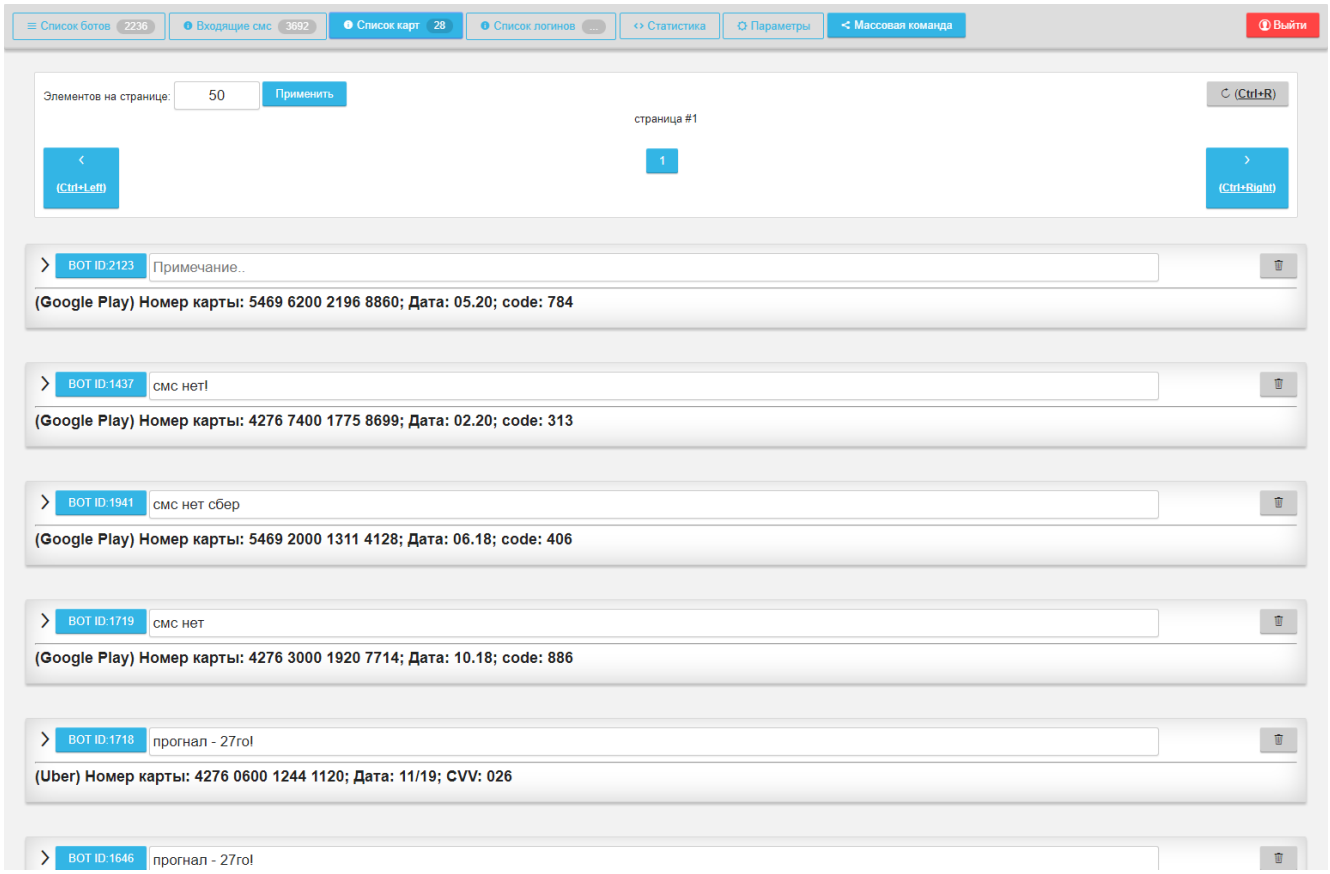
Malware name	Regions attacked	Detection
FlexNet	Russia	2014

The Trojan requests device administrator privileges. The text of the request is masqueraded as the Google Play Agreement, which distracts the user and leads to the confirmation of rights.

On command from the C&C server the application can:

- change the address of the C&C server
- send an SMS message to the specified number
- send spam messages with the specified text
- forward text messages to the C&C server
- reply to SMS messages and delete them to hide from the user
- run USSD requests
- create a scheduled task - setting up a command template for new bots, taking into account the operator and the country.

Also, Group-IB specialists determined that authors added phishing dialogs disguised as Google Play and the Uber application to the recent version of FlexNet. The pushing windows are designed to receive victim's bank card data.



Screenshot – FlexNet control panel, a tab with intercepted bank cards

Malware name	Regions attacked	Detection	Notification
Agent.BID	Russia	2015	CP-1565

A new campaign using the Agent.BID banking Trojan for Android has been active since Q2 2017. The Trojan is distributed via SMS. Once installed on the victim's device, the application displays an icon with the "Sberbank" logo. The threat is designed to steal online banking credentials and bank card data. Also, the malware is able intercept and send SMS messages. The malware is currently targeting VTB24, Alfa Bank, Sberbank and QIWI. It's worth reiterating that in 2016 this Trojan was actively used by intruders, however in November its activity significantly decreased.

Threat name	Detection	Regions attacked
Agent.sx	2015	Russia

Criminals use this banking bot, which has capabilities to send and intercept SMS messages, to perform unauthorized money transfers through SMS banking. Developers have added an auto-reply function to the malware control panel, which enables attackers to send messages with transfer confirmation automatically. The program also has the functionality to parse SMS messages in order to obtain victim's card balance. This parser can be customized for any bank. The Trojan also has capabilities to collect bank card data using a Google play phishing dialog.

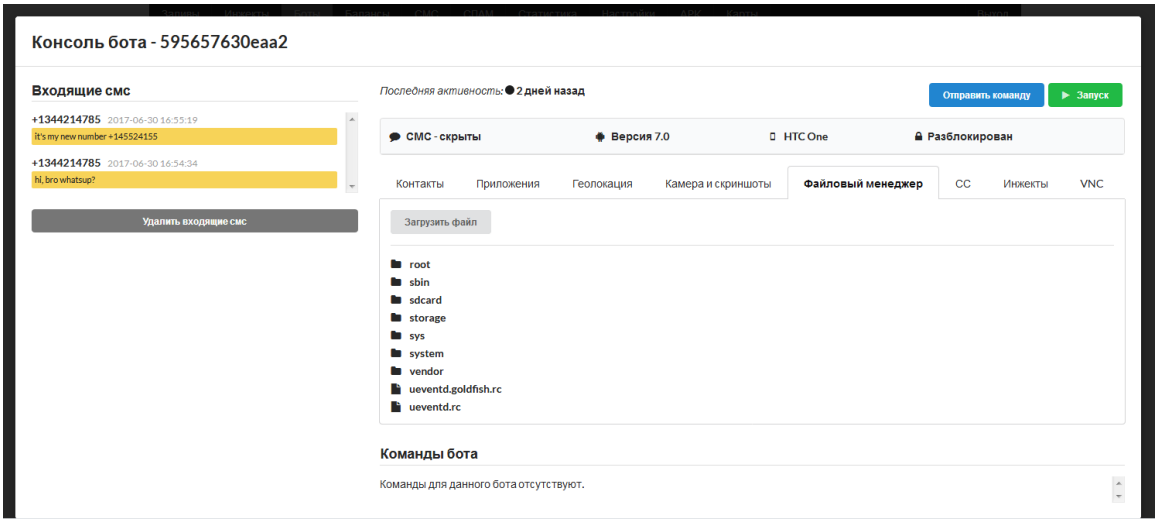
Threat name	Detection	Regions attacked
Gugi/Limebot/Lipton	August 2016	Russia

The Trojan is designed to overlay applications with phishing windows in order to steal mobile banking data and credit card data. In addition, it is able to steal SMS and contact lists, perform USSD requests and send SMS on command from the C&C server. In Q3 2017, Gugi/Limebot/Lipton attacked the following banks: VTB24, Raiffeisen Bank, Tinkoff Bank, Alfa Bank, Sberbank. The Trojan spreads via SMS spamming and uses fake windows to capture data.

Malware name	Regions attacked	Related notifications	Detection
Easy	Global	CP-1584	June 2017

The Easy banking bot has a standard set of functions: it intercepts and sends SMS messages, collects data on the device, display fake pages and captures geolocation data. The Trojan also has the following specific features:

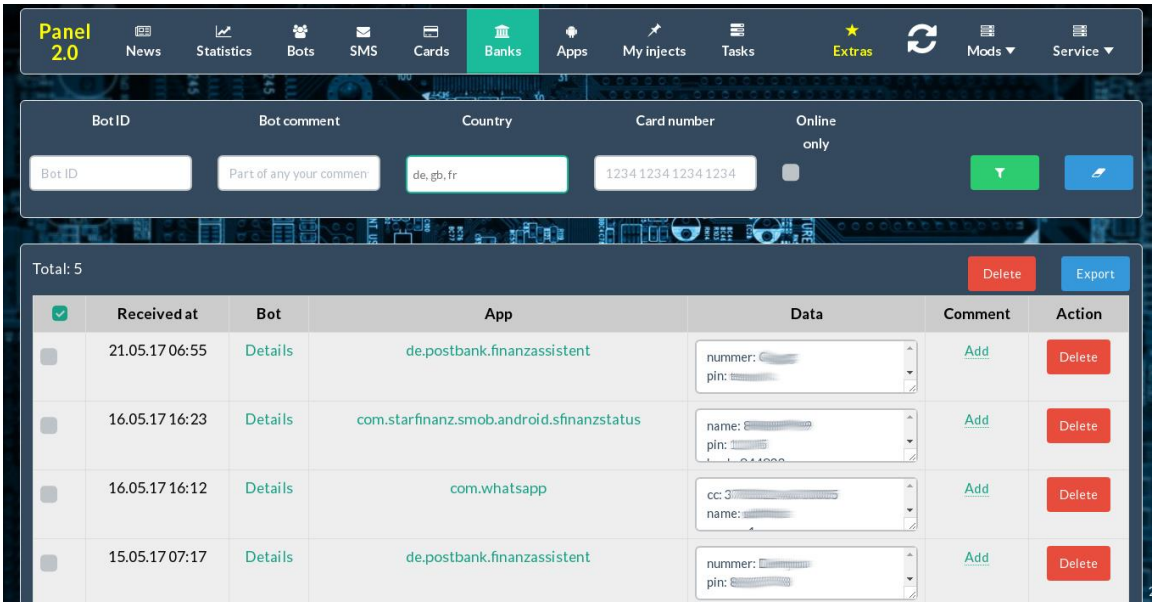
- After installation, the Trojan acquires administrative rights and root
- An administrative panel may be located in .onion (TOR)
- The maximum application size is 100 KB
- It automatically checks the balance of bank accounts via SMS
- Covertly updates itself
- Multilanguage interface
- VNC (Virtual Network Computing) is under development



Screenshot – Control panel of the Easy bot

Malware name	Regions attacked	Related notifications	Detection
Exobot 2.0	Global non-CIS	CP-1585	June 2017

According to its developer, a new version of the Exobot bot is entirely written from scratch and has all the functions of the previous version. In addition, the author separately noted that now a mojor part of the Trojan is loaded dynamically, which allows changing web fakes and domains on infected devices. Trojan runs on all Android versions. Exobot 2.0 has an updated administrative panel with new features. It is also worth noting that the author prohibits attacks in the following regions: the US, Canada and the CIS. This means that it will be primarily used to attack European banks.



Screenshot – Control panel of the Exobot 2.0 bot

Malware name	Regions attacked	Related notifications	Detection

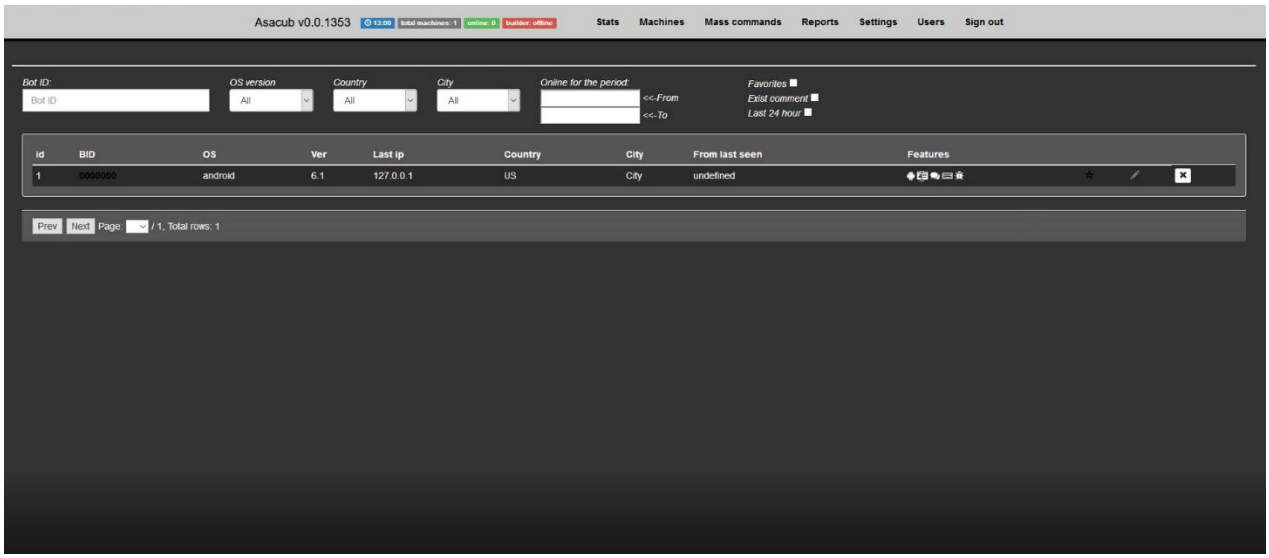
Asacub	Global	CP-1595	2014

In late June, researchers tracked a new wave of malicious SMS messages with a link to the Asacub banking Trojan. Once the victim's device is infected, the Trojan starts sending messages to the entire contact list, and sends SMS to short number 900 in order to find out the balance of the victim's bank card (in the event the victim is a client of Sberbank).

Currently, Asacub is the most active Android Trojan in Russia. It has the following functionality: sends a list of installed applications, the browsing history and contact list to the C&C server, sends SMS messages to the specified number, downloads the history of messages to the C&C server, displays phishing pages over legitimate applications, forwards calls to the specified number, sends USSD requests, downloads files from a specified link and installs them.

In the past, the Trojan was distributed privately, but in August it became available for purchase on an undeground forum. The malware has all the standard capabilities of a banking trojan for Android, including displaying fake pages of certain banking applications.

Forum users claimed that the sold version was not complete; the seller had a financial conflict with one of the buyers, as a result, on September 19, the topic of the sale was closed. Probably, Asacub will continue to be sold privately. We forcast possible attacks on banks in different countries in addition to Russian ones.



Screenshot – Control panel of the Asacub's new version

Malware name	**Regions attacked**	**Related notifications**	**Detection**
CryEye	Global non-CIS	CP-1596	2017

In July, the CryEye banking Trojan for Android appeared for sale on an underground forum. Like all modern mobile Trojans, it has the functionality to intercept/send SMS messages, transfer information about the victim and installed applications to the C&C server, as well as display fake pages. Also, CryEye can block the operation of anti-virus software. The package includes web injects for a number of banking applications targeting banks in Turkey, Germany, Poland, Australia, France, Great Britain.

Malware name	**Regions attacked**	**Related notifications**	**Detection**

Cannabis	Global non-CIS	CP-1598	2017

In late August, GanjaMan, the author of infamous GM bot (aka Mazar) and other malicious programs for Android, published an announcement about sales of the source code of the Cannabis banking Trojan for Android. The attacker claims he will sell it to five customers.

Functions:

- Includes software source code with the protocol of communication between the application and the C&C server
- SMS Manager
- VBV grabber
- A set of standard fake pages for banks
- Push, BlackList, GrabContacts functions

It is interesting to note that in March 2016 GanjaMan was banned on the underground forum, but since April 2017 his account has been active again.

Malware name	Regions attacked	Related notifications	Detection
Android-loader by Trafimer	Global	CP-1597	2017

On underground resources, Android-loader tool built into a legitimate application placed on Google Play, is offered for purchase. The seller is an attacker monickered Trafimer. The customer who purchases this product receives a link to the Google Play application with a built-in loader and access to the control panel of the loader (the language of the panel is Russian), where the user can see all the devices infected by the loader and distribute other malicious software to them. For each new customer, a new application is created on Google Play.

Malware name	Regions attacked	Detection
Marcher Alien-bot	Australia France Germany Turkey Poland	2016

Marcher is a banking Trojan for Android that is employed by a variety of hacker groups. Also, there is Marcher 2 (aka Alien bot) developed based on the Marcher source code. Its main basic functionality includes grabbing bank card data, interception of SMS messages, displaying fake banking app pages.

Malware for PC

APT name	Regions attacked	Related notifications	Operation start
Buhtrap	Russia	CP-1593	2015

The Buhtrap criminal group and their malware of the same name have been known since 2015. In early 2016, the Buhtrap source code was made public, after that the program was widely used by other cybercriminals.

Recently, a new attack was discovered, which also used leaked source code or a version of the Buhtrap malware purchased from the criminal group. The attack appears to have been conducted by other criminals rather than the Buhtrap group.

Group-IB specialists have identified a number of compromised legitimate resources for accountants and layers (such as glavbukh.ru, klerk.ru, careerist.ru and others). Users, who entered compromised websites, were stealthily redirected to a server with an injected exploit kit. In the event it detected vulnerabilities in a web browser, the PowerShell script was executed, which led to the Buhtrap banking Trojan being downloaded.

These attacks are targeting companies working with online banking systems.

Threat name	Detection	Regions attacked
RTM	2015	Russia

The program is written in Delphi and has a modular architecture. Based on its functionality, the Trojan targets online banking and payment systems. A new Trojan sample searches for the following online banking systems on the infected machine: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, VTB24.

The RTM group has the main control panel and a separate Proxy panel that contains specific banks which they attack in a special fashion – all requests are forwarded to phishing servers used as proxy.

Malware name	Regions attacked	Detection
Trickbot	Global	Fall 2016

In July researchers detected a new campaign using the TrickBot banking Trojan. Criminals disguised their emails as letters from Lloyds Bank (UK) and send the spam at the speed of over 75,000 messages per 25 minutes. After the system was infected, TrickBot waited for the user to visit the bank's website. When it happened, the Trojan redirected the victim to a phishing website imitating Lloyds Bank. It was difficult to detect this fraud: the attackers showed a victim the correct URL and the resource even had a valid SSL certificate.

A newly observed version of the TrickBot banking Trojan includes a worm-like malware propagation SMB module that allows it to spread locally to all accessible machines. The malware has a module designed to steal data saved by Microsoft, including user credentials, and a module with capabilities to steal data from the browsers, including Cookies, HTML5 Local Storage, Browsing History, Flash LSO (Local Shared Objects), and URL hits, among other info. Inside the binary, researchers detected a list of targets that includes websites from countries all around the world – Japan, France, Poland, Italy, Peru, Norway, and many more.

In early September, a new variant of banking Trojan was discovered, which appeared to be stealing funds from the Coinbase cryptocurrency wallet service.

On September 15, researcher identified a new Trickbot module called WormShare that spreads via remotely creating processes.

Malware name	Regions attacked	Detection
Ramnit	Global	2010

The Ramnit banking Trojan was first discovered in 2010. In 2015, with the assistance from Europol, the Ramnit botnet was destroyed. But in Q3 2017 we again observed the activity of this malicious program. We saw it being used to compromise credentials for online banking of a Dutch bank and cards of banks in Canada, Germany, the United States, and France.

Malware name	Regions attacked	Related notifications	Detection

Xbot	Global	CP-1603	August 2017

In late August, on an underground forum, a new banking bot for Windows appeared on sale. Xbot has the functionality of web injects, form grabbing and HVNC. The malware is most likely developed based on the source code of the TinyNuke banking Trojan.

The seller also informed that he was a member of the NZMR group.

The author claims that the bot runs on all Windows versions and in all browsers.

For about a month, the sellers has been promising to pass the verification of their product from the administrator of the forum, but there are still no real results of this test.

Malware name	Regions attacked	Related notifications	Detection
hVNC by a.wesker	Global	CP-1602	2013

On August 24, 2017 a Trojan for Windows Vista that can control users' PCs appeared on the underground forum exploit.in. It was developed by a user called "a.wesker" who has not been active since May 2017. The source code is being sold for $15,000 for one customer or for $5,000 for three customers.

Malware name	Regions attacked	Detection
Gozi (ISFB)	Japan, Australia	2009

According to Group-IB specialists, in Q3 2017 the Gozi (ISFB) banking Trojan attacked Japan and its purportedly modified version attacked Australia. It is worth reiterating that source code of this Banking malware was published online in April 2016.

In Australia the modified version of Gozi was distributed using a JavaScript code.

The Gozi version being distributed in Japan does not differ from the source code published in 2016. It is spread though phishing emails with malicious attachments (Microsoft Excel documents).

Name	Detection	Countries attacked
Qbot	2009	USA Netherlands Canada Russia Netherlands

Discovered in 2009, the QakBot or Qbot banking Trojan has significantly evolved over time. The malware features a modular design, is multithreaded, and includes components designed to steal keystrokes, online banking credentials, digital certificates, authentication tokens, and cookies, implement a backdoor, and create a SOCKS proxy. It also has the functionality to bypass AV solutions. The program is primarily used to target businesses, stealing money from their bank accounts. QBot is able to spread like a worm by self-replicating through shared drives and removable media.

Examples of attacked banks:

ABN AMRO Bank (Netherlands)
Citibank
Huntington Bancshares, Inc.
Toronto-Dominion Bank (TD BANK)
Bank of America
First Citizens Bank
Citizens Financial Group
First Tennessee Bank
Banco Bilbao Vizcaya Argentaria (BBVA)
Eastern Bank

Fifth Third Bank (53 bank)
Alpha bank
FirstMerit Bank
JPMorgan Chase
KeyBank
Scotiabank
Capital One
Wells Fargo

Name	Detection	Countries attacked
Tinba	2012	Spain USA Poland Italy France United Kingdom Germany

Examples of attacked banks:

Bancopopular
Fifth Third Bank (53 bank)
JPMorgan Chase
Aliorbank
Poste (it)
Banesto (es)
ANZ
Bnpparibas
Caixa
Chase
Citibank
Credit Agricole
Wellsfargo
Santander
HSBC
Barclays
Lloyds bank
Norisbank (de)
Intesa (it)
Bankofamerica

Name	Detection	Countries attacked
Zeus	2007	Spain USA Australia United Kingdom Italy Turkey Germany Belgium

Examples of attacked banks:

Bancopopular
Fifth Third Bank (53 bank)
Caixa
Australia and New Zealand Banking Group
Halifax
HSBC Bank
Wells Fargo
Usbank
Citibank (de)
Unicaja
Popso
Bancopastor
Lloydsbank
Norisbank (de)
Isbank
Santander
Procreditbank (bg)

Name	Detection	Countries attacked
ZeusVM (KINS)	2013	USA South Africa Canada Spain Germany Belgium United Kingdom Italy

Examples of attacked banks:

ABSA	BBVA
HSBC	Norisbank
Wellsfargo	Citibank
Usbank	Procreditbank (bg)
TDCanadatrust	Barclays
Suntrust	Lloyds
53.com	Halifax
Bank of America	Bancopopular
Chase	Bancopastor
Openbank (es)	Poste
Banesto	Iwbank
Santander	

Name	Detection	Countries attacked
Atmos	2015	France

Examples of attacked banks:
Credit Agricole
Bnpparibas
LCL bank
CIC bank
Creditmutuel

Name	Detection	Countries attacked
Dridex	2014	Global

The Dridex banking Trojan has been evolving since 2014. It is designed to steal login credentials for banking systems by embedding itself in web browsers.

One of the recent attacks appears to have targeted Xero customers. This is a New Zealand company that provides cloud-based accounting solutions for small and medium-sized businesses. Malicious emails contained a document with JavaScript that downloaded Dridex onto the machine.

The subject of the letter was "Xero Billing Notifications", the sender's server was the domain xeronet.org, which was registered by the attackers.

Name	Detection	Countries attacked
Emotet	2014	Global

Emotet is a modular banking Trojan that includes the following modules: its own installation module, a banking module, a spam bot module, a module for data from MS Outlook and a module for organizing DDoS attacks.

In July 2017, an Emotet sample was identified, which has the ability to self-propagate through the local network, due to the brute-force module, through which it accesses various accounts.

Recently, Emotet was distributed using spam mailouts containing an exploit for the CVE-2017-0199 vulnerability. In 2017, malicious emails containing Emotet were tracked in the United Kingdom, the United States, and Turkey. In August 2017, specialists at Trendmicro reported that Emotet had been used to deliver the Dridex banking Trojan to infected devices.

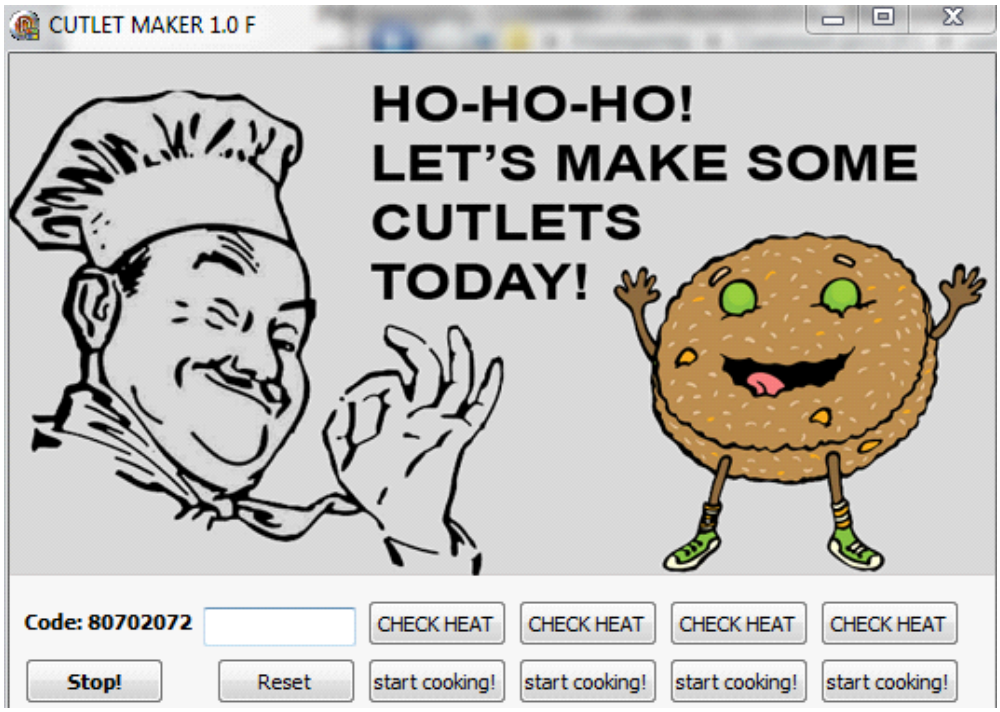
Attacks on ATM and POS terminals

- The Cobalt group continued attacking ATM control systems. Their ultimate goal is to connect to an ATM dispenser and send commands to deplete cash cassettes using malware.

- On underground resources, a malicious program for Wincor ATMs called "Cutlet" appeared on sale. This program is designed to make ATM cassettes dispense all banknotes.

Malware name	Regions attacked	Related notifications	Appearance
Cutlet	Global	CP-1592	April 2016

In June, a malicious program designed to attack Wincor ATMs appeared on sale on underground forums. The toolkit includes the malicious program, a password generator (which is required to infect new ATMs), and a detailed instructions on the tactics of infection and the use of the malicious program to commit theft.

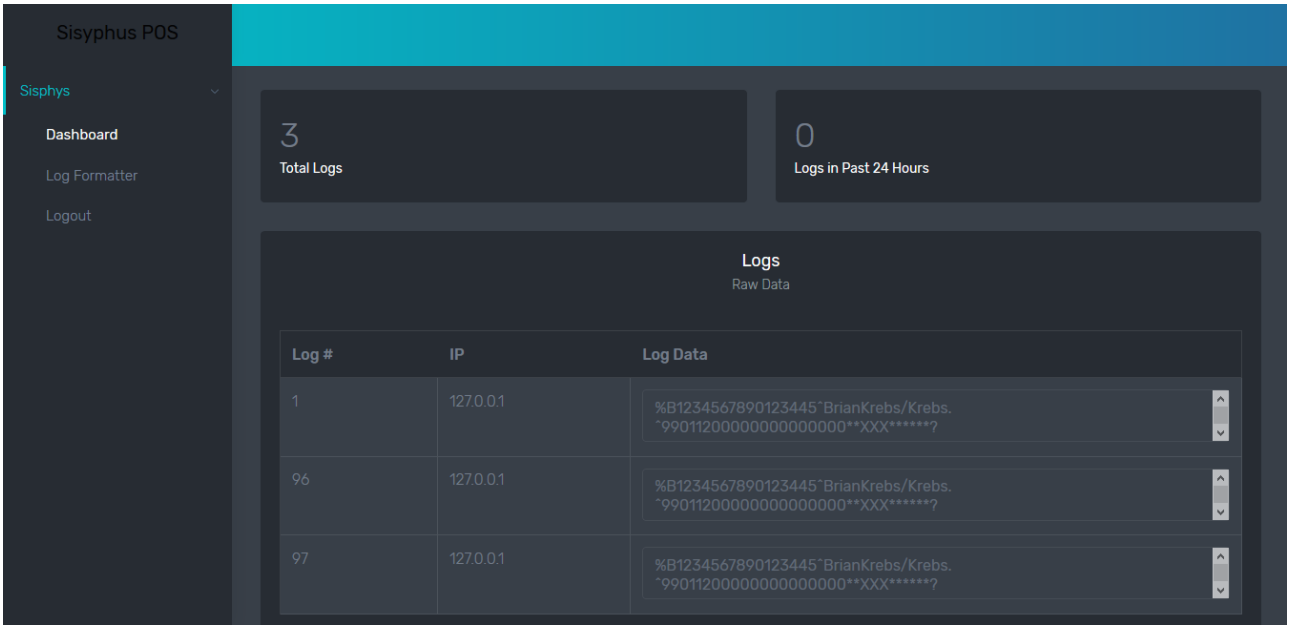


Screenshot – Interface of the Cutlet malware

- On underground resources, a malicious program for POS terminals dubbed "Sisyphus" appeared on sale.

Malware name	Regions attacked	Related notifications	Appearance
Sisyphus POS	Global	CP-1608	September 2017

This malicious software allows the attacker to compromise bank card data (Track 1 and Track 2), which are processed by the infected POS terminal. The malicious program is written in C and, according to its author, differs from such popular malicious programs for POS terminals as Alina and Dexter. The malware does not write collected information to disk, all data is stored in memory and sent to the administrative panel as soon as the malicious software collects 3 cards. The administrative panel is written in PHP, according to the author, the code employs *prepared statements* and *output escaping* to protect the control panel against SQL injection. The low enough cost of this malicious program can lead to its large-scale use.



Screenshot – Sisyphus POS control panel

- Incidents using Blackbox devices for thefts from ATMs were identified in Ukraine, Romania, Switzerland, and Great Britain during the reporting period.

- LockPoS is a new malicious program for POS terminals that actively operates through botnets that previously spread FlokiBot malware. In July, LockPoS targeted Brazilian companies and was not detected by antivirus tools. In March, experts from Cisco and Flashpoint released a joint report warning of the increasing popularity of FlokiBot malware for attacks on POS terminals, developed using the source code of the Zeus 2.0.8.9 Trojan. Flashpoint analysts believe that FlokiBot is employed by 10 criminal groups, who have conducted successful attacks on companies in the USA, Canada and Brazil.

- Researchers at IOActive discovered two vulnerabilities in Opteva ATMs (Physical and Authentication Bypass) that, when combined, may allow an unauthorized user to vend notes from the device. The affected devices include some versions of Opteva ATMs based on the Advanced Function Dispenser (AFD) platform. These models are designed with physical separation between the safe and the internal operating system, each with its own authentication requirements.

  IOActive researchers began their investigation by physically compromising the device. Using a metal rod inserted through a speaker hole on the front of the ATM, the researchers were able to lift a metal locking bar to gain access to the upper cabinet of the ATM, which contains the computer. Once the research team had access to the cabinet, they removed the USB connection from the Windows host and gained a direct line of communication to the AFD controller within the safe. With access to the

upper cabinet and the operating system's firmware, IOActive researchers determined that another vulnerability would be necessary to gain access to the contents of the safe. Since the AFD governs the security of the safe, IOActive reverse engineered the AFD's protocol and firmware. Using the USB that connects the AFD to the computer in the upper cabinet, the team was able to initiate two-way communication. This would normally require a shared encryption key and a device identifier; however, the team was able to complete the authentication protocol unencrypted and set up communications without properly authenticating. This allowed the team to act as an authenticated user and gain access to the contents of the safe.

Specialists informed Diebold about the physical vulnerability in February 2016. A year later, in February 2017, the manufacturer was provided with information on a software vulnerability in the devices. However, the company reacted only in March of this year stating that "“[your]..]..system is very old (2008/2009 vintage) and is unpatched." Their offer to retest current firmware was ignored, as were further attempts to follow-up with Diebold.

Other attacks and tools

Exploits used to perform targeted attacks	Regions attacked	Related notifications
Exploi for the CVE-2017-8759 vulnerability and other exploits of the same author	Global	CP-1610

To attack Russian government institutions, FinSpy exploited the CVE-2017-8759 vulnerability, which at the time was a zero-day vulnerability. Group-IB staff detected that the alleged author of this 0day exploit had been selling it on an underground forum since April. This attacker is a Russian speaker. Our specialists also found out that he offered other exploits purchase, in particular a 0day for MS Office. Therefore, in the future, new targeted attacks exploiting 0day vulnerabilities are possible.

Exploits used to perform targeted attacks	Regions attacked	Related notifications
Disdain exploit kit	Global	CP-1594

In August, on several underground forums, specialists detected an announcement on sales of the Disdain exploit kit that contained the following exploits:

CVE-2017-5375 - FF
CVE-2017-3823 - Extension (Cisco Web Ex)
CVE-2017-0037 - IE a
CVE-2016-9078 - FF
CVE-2016-7200 - EDGE + IE a
CVE-2016-4117 - FLASH
CVE-2016-1019 - FLASH
CVE-2016-0189 - IE
CVE-2015-5119 - FLASH
CVE-2015-2419 - IE
CVE-2014-8636 - FF
CVE-2014-6332 - IE
CVE-2014-1510 - FF
CVE-2013-2551 - IE
CVE-2013-1710 - FF
It is most likely a new 'clone' of the Beps Exploit Kit.

Exploits used to perform targeted attacks	Regions attacked	Related notifications
'Shadow Brokers' dump of tools	Global	DL-1567-2

In May Shadow Brokers introduced a monthly subscription service for new tools and exploits from the NSA archives. On September 06, 2017 they informed that their monthly dump service is still active, stating the leaks will now be semi-monthly.

Previous data dumps are also available for purchase. That said, each new release costs much more expensive than the previous one (for example, the June data dump costs 100 ZEC, which is around 23,912.00 USD, the dump for September 15 costs 1000 ZEC ~ 239,120.04 USD, the dump for September 30 costs 2000 ZEC ~ 478,240.08 USD, the dump for November 15 costs 16000 ZEC ~ 3,825,920.61 USD).

This September dump also contains a link to the Manual to August Dump, which is the manual for the NSA's UNITEDRAKE tool, which was purportedly included in the August dump. UNITEDRAKE is a system designed to collect data on Windows devices developed by Contact Software, Inc.

Exploits used to perform targeted attacks	Regions attacked	Related notifications
Blueborne vulnerabilities	Global	CP-1611

On September 12 Armis Labs reported eight Bluetooth-related vulnerabilities in various platforms, such as Windows, Linux, Android and iOS. Four of them were classified as critical. The BlueBorne attack vector can be used to conduct a large range of offenses, including remote code execution on a vulnerable device.

Attack name	Regions attacked	Operation start
Attack using the RouteX malware designed to infect routers	Global	2017

A threat actor monickered Links, attacks Fortune 500 companies using RouteX malicious software. He exploits the CVE-2016-10176 vulnerability in Netgear WNR2000 routers. This vulnerability allows unauthenticated attackers to perform sensitive, admin-level actions. After successful exploitation of the vulnerability, the attacker downloads and runs RouteX Trojan.

The RouteX malware has two main functions. The first is to install a SOCKS proxy on each infected device.

The second is to add iptable rules (a command-line firewall utility) that prevent further exploitation of the same vulnerability, but also restrict access to the device to a few IP addresses, most likely under the attacker's control.

After that, the hijacked Netgear routers are used to perform credential stuffing attacks – brute-force operations, in which a threat actor takes credentials from publicly leaked data breaches to test username and password combinations.

The size of this botnet made up of Netgear routers is currently unknown, because the infected devices do not maintain a persistent connection to the C&C server and the attacker connects to devices only when he needs to.

State-sponsored APT

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT name	Regions attacked	Operation start
Turla	Europe, USA	2016

In August 2017, ESET specialists reported that a Russian hacker group, tracked as Turla, used a previously undocumented backdoor called Gazer. This backdoor is employed in attacks on government and diplomatic organisations primarily in Southeastern Europe and in former Soviet nations (including embassy and ministry systems). The malicious program was developed by the suspected Russian APT group Turla to steal money.

According to ESET researchers, the tactics of attackers were similar to their previous attacks - infection of the system with a first stage backdoor (for example, using targeted phishing), installation of a second stage backdoor (Gazer, and formerly used Carbon and Kazuar) to steal data.

Gazer receives encrypted tasks from a command-and-control server that can be executed either on an already infected machine or by another machine on the network. Gazer authors also make extensive use of their own customized cryptography, using their own library for 3DES or RSA. The RSA keys embedded in the resources contains the public server's key controller by the attacker and a private key.

These keys are unique for each sample and are used to encrypt and decrypt the data sent/received to/from the command-and-control server. Furthermore, the notorious Turla group was seen using a virtual file system in the Windows registry to evade antivirus defenses and continue to attack the system.

As usual, the Turla APT group makes an extra effort to avoid detection by wiping files securely, changing the strings and randomizing what could be simple markers through the different backdoor versions. In the most recent version, Gazer authors modified most of the strings and inserted "video-game-related" sentences throughout the code.

In addition, in August 2017 specialists Kaspersky Lab reported a malicious campaign called WhiteBear, which appeared to be the second phase of White Atlas, another Turla project. As with previous Turla campaigns, WhiteBear's command and control infrastructure also is comprised of a collection of compromised websites and hijacked satellite connections. Some portions of the infrastructure that WhiteBear is using was also used previously in other Turla campaigns, such as one involving a data-stealing backdoor dubbed Kopiluwak. In addition, attempts to deploy WhiteBear modules are always preceded by attempts to deploy WhiteAtlas as well, further suggesting a link between the two campaigns.

Turla (aka Snake/Uroburos/Venomous Bear/Krypton) is believed to have been active since 2006. However, in April 2017, security experts uncovered possible connections between the modern threat actor and the Moonlight Maze attacks, which were conducted back in the 90s.

APT name	Regions attacked	Operation start
Targeted attack using NetWire RAT	Croatia, United Arab Emirates, Egypt, Kuwait, Germany	April 2017

Security specialists revealed the identity of the criminal behind a series of cyberattacks targeting over 4,000 companies in the energy, mining and infrastructure sectors. The campaign started in April 2017 and lasted 4 months. The global scale of the campaign and the targeted organizations could mean that an expert gang or state-sponsored agency was behind it. However, through investigation it was discovered that the attacks were organized by a 25-year-old Nigerian citizen. The campaign also received a name of the status used by the attacker on Facebook: *'get rich or die trying'*.

The attacker sent out fraudulent emails disguised as letters from oil and gas giant Saudi Aramco, the world's second largest daily oil producer, targeting financial staff within companies to trick them into revealing company bank details, or open the email's malware-infected attachment.

The malware used is NetWire, a remote access Trojan which allows full control over infected machines, and Hawkeye, a keylogging program.

The attacks were launched from the two email addresses sale.cement_till_tw@yahoo.com and cciticarinternational@yahoo.com. The campaign resulted in 14 successful infections and allowed the author to earn thousands of dollars. Companies that were infected during the campaign include:

- A marine and energy solutions company in Croatia
- A transportation company in Abu Dhabi
- A mining company in Egypt
- A construction company in Dubai
- An oil & gas firm in Kuwait
- A construction organization in Germany

APT name	Regions attacked	Operation start
APT28 (Sofacy, Fancy Bear)	Europe, Middle East	July 2017

The Russian hacker group APT28 or Fancy Bear began using the EternalBlue exploit (CVE-2017-0144), which is a leaked NSA hacking tool. APT28 conducted a series of attacks targeting hotels in at least seven European countries and one Middle Eastern country in early July.

According to FireEye researchers, the attackers were focused on collecting confidential information on Western government and business travelers using hotel Wi-Fi networks.

The first stage of the attack involves sending phishing emails containing a malicious document disguised as a hotel booking form. When the victim opened the document, a dropper was installed on the computer, which downloaded the Gamefish malicious software. This Trojan was used to ensure persistence in the system and subsequently install the Responder tool that would help the infiltrators steal network usernames and passwords.

Once inside the network of a hospitality company, APT28 sought out machines that controlled both guest and internal Wi-Fi networks. To spread through the hospitality company's network, APT28 used a version of the EternalBlue SMB exploit. This was combined with the heavy use of py2exe to compile Python scripts.

Upon gaining access to the machines connected to corporate and guest Wi-Fi networks, APT28 deployed Responder which facilitated NetBIOS Name Service (NBT-NS) poisoning. This technique listens for NBT-NS (UDP/137) broadcasts from victim computers attempting to connect to network resources. Once received, Responder masquerades as the sought-out resource and causes the victim computer to send the username and hashed password to the attacker-controlled machine. APT28 used this technique to steal usernames and hashed passwords that allowed escalation of privileges in the victim network.

APT name	Regions attacked	Operation start
Dragonfly 2.0	Europe, North America, Turkey, Switzerland	2015

The energy sector in Europe and North America is the target of a new wave of cyber-attacks, which can give criminals the opportunity to seriously disrupt operation of affected organizations. A group called "Dragonfly" is believed to be behind these attacks. The group has been active since at least 2011. They have again continued attacking over the past two years after some period of inactivity. The campaign, which was detected in late 2015, was named "Dragonfly 2.0". The tactics and tools that are currently employed are the same as in their previous campaigns.

According to a study by Symantec, cybercriminals have attacked energy companies in the US, Europe and at least one company in Turkey. Attackers were able to penetrate into the internal networks of at least 20 companies and gained control over the key elements of the control system responsible for supplying electricity.

Experts say that Dragonfly's activity is currently aimed at gathering information, including that one on the internal work of energy companies.

The first attack was discovered in December 2015. The attackers sent out email messages to the targets in the energy sector. The letters were disguised as invitations to a New Year's party.

The second wave of email campaigns was conducted during 2016 and 2017. The letters contained very specific information related to the energy industry, as well as some general business problems. After the attached malicious document was opened, it would try to retrieve the victim's network credentials and forward it to an external C&C server. In some of the emails, Dragonfly used the Phishery toolkit to steal the victim's credentials through web injection attacks. This tool was made public on Github in late 2016.

In addition, Dragonfly used watering hole attacks to collect network credentials by attacking websites that were likely to be visited by those involved in the energy sector.

The compromised data were used in subsequent attacks on target organizations. In one case, after the victim visited a hacked server, criminals used PowerShell to install Backdoor.Goodor on his machine 11 days later. Backdoor.Goodor provides attackers with remote access to the victim's machine.

In the 2016 and 2017 campaigns, the group used the Shellter tool to develop Trojan applications. In particular, Backdoor.Dorshel was delivered as a Trojan version of standard Windows applications.

APT name	Regions attacked	Operation start
Spring Dragon	Taiwan, Indonesia, Vietnam, Philippines, Hong Kong, Malaysia, Thailand	2017

Spring Dragon (aka Lotus Blossom, Elise or Esile) is a hacker group that conducts campaigns, mainly in countries and territories around the South China Sea, starting in 2012. Their main targets are high-level government institutions and political parties, educational institutions, as well as telecommunications companies. According to security experts, Spring Dragon have used more than 600 samples of malware in their attacks in recent years.

The majority of the attacks were observed in the countries of the South China Sea, including Taiwan, Indonesia, Vietnam, the Philippines, Hong Kong, Malaysia and Thailand.

The group has a huge cyber-arsenal, which they have been developing and upgrading for years. The hackers have different backdoor modules with unique characteristics and functionality. They manage a large C&C infrastructure that includes more than 200 unique IP addresses and C&C domains.

All backdoor modules allow the attacker to download files to the victim's computer, upload files to the C&C server, and execute any executable file or any command on the victim's machine.

The majority of the C&C servers used by Spring Dragon are located in Hong Kong and the US, other servers have also been found in Germany, China and Japan.

APT name	Regions attacked	Operation start
DarkHotel	North Korea	September 2016

The DarkHotel group uses new attack methods targeting government employees in North Korea, according to a report published by Bitdefender in July 2017.

Cybercriminals were first reported in November 2014. The attackers targeted their victims using several methods, including through their hotel's Wi-Fi, zero-day exploits and peer-to-peer (P2P) file sharing websites.

early one year later, the threat group was observed using new attack techniques and an exploit leaked from Italian spyware maker Hacking Team.

Up until recently, the attacks appeared to focus on company executives, researchers and development personnel from such sectors as defense industrial base, military, energy, government, NGOs, electronics manufacturing, pharmaceutical, and medical.

The new attack was called "Inexsmar" and targeted political figures.

The initial Trojan downloader, delivered via phishing emails, collects information on the infected device and sends it back to its C&C server. The email contains an attached document titled “Pyongyang e-mail lists - September 2016,” which provides a list of email contacts for various organizations in North Korea’s capital city. If the compromised system meets requirements (i.e. it belongs to an individual who is of interest), the first stage DarkHotel downloader, disguised as a component of OpenSSL, is fetched.

The original Trojan downloader is delivered via phishing emails, collects information about the infected device and sends it back to the command server. The phishing email contained a file called "Pyongyang e-mail lists - September 2016" containing a list of email addresses and contacts of various organizations in the North Korean capital.

If a hacked system meets the requirements (that is, it belongs to an individual that is of interest), the Trojan is masked for the OpenSSL component and connected to the C&C server for further instructions.

APT name	Regions attacked	Operation start
DragonOK	Cambodia	June 2017

A new attack by the DragonOK cybercrime group, discovered on June 21, 2017, targeted victims in Cambodia. Specialists note that the attack was conducted using KHRAT. This tool has a standard set of RAT features, including provision of remote access to the victim's computer.

On June 21, 2017, specialists discovered a malicious document named "Mission Announcement Letter for MIWRMP phase 3 implementation support mission, June 26-30, 2017 (update).doc". MIWRMP (Mekong Integrated Water Resources Management Project) is a multi-million dollar, World Bank funded project relating to effective water resource and fisheries management in North Eastern Cambodia. The document tricked the victim into enabling macros to run malicious JavaScript code.

During the attack, hackers used the domain "update.upload-dropbox[.]com", which was masked as the well-known file hosting Dropbox. The above-mentioned domain was placed on the compromised server of the Cambodian Government.

Based on the name of the document and the website used for its distribution, security specialists determined that the attack had targeted government organizations in Cambodia.

The researchers also noticed that the threat actor gathered data about visitors to a compromised website, such as Browser Fingerprint, cookies, HTTP referrer and Flash Player version.

The DragonOk group was first discovered in September 2014. They are known for their attacks on the corporate sector in Japan and Taiwan.

APT name	Regions attacked	Operation start
Attack using the ShadowPad backdoor	Global	July 2017

In July 2017, Kaspersky Lab was approached by a financial institution to examine suspicious DNS requests originating on a system involved in the processing of financial transactions. Further investigation showed that the suspicious requests were actually the result of the activity of a malicious module hidden inside a recent version of the legitimate software NetSarang. Following the installation of an infected software update, the malicious module would start sending DNS queries to specific domains (its command and control server) at a frequency of once every eight hours.

The requests would contain basic information about the compromised company. If the attackers considered the system to be "interesting", the C&C server would reply and activate a fully-fledged backdoor platform that would silently deploy itself inside the attacked computer. After that, on command from the attackers, the backdoor platform would be able to download and execute further malicious code.

The researchers said they could confirm activated payloads in the Asia Pacific region. NetSarang reacted fast and released an updated version of the software with the vulnerability patched.

The affected NetSarang products include:

- Xmanager Enterprise 5 Build 1232
- Xmanager 5 Build 1045
- Xshell 5 Build 1322
- Xftp 5 Build 1218
- Xlpd 5 Build 1220

APT name	Regions attacked	Operation start
Lazarus	USA	April 2017

From April to July 2017, the Lazarus group carried out targeted attacks on US military contractors.

According to a study by Palo Alto Networks, the criminal group initially focused on Korean-speaking individuals, but later switched to English speakers.

The attack was carried out using Word documents containing malicious macros. Once opened, both files display a document containing information on vacancies, job responsibilities in US companies and the domestic policy of US military contractors. The information about the vacancies was copied from the official websites of the respective contractors.

In this attack, hackers partially employed the techniques, C&C servers and software that had been used by Lazarus in previous attacks.

Lazarus first became known in 2007. The group is linked to such major attacks as theft from the Central Banks of Bangladesh and hacking Sony Pictures.

APT name	Regions attacked	Operation start
CopyKittens (Rocket Kittens)	Israel, Saudi Arabia, Turkey, USA, Jordan, Germany	2017

An Iranian hacker group called CopyKittens (aka Rocket Kittens), which is engaged in international espionage, continued their activity in 2017. Specialists noted that the most frequent victims of criminals were government agencies, defense companies, subcontractors and large IT companies in Israel, Saudi Arabia, Turkey, the United States, Jordan and Germany. Their activity was dubbed Operation Wilted Tulip.

In their attacks, CopyKittens combines various attack methods: phishing letters, compromising resources visited by potential victims (so-called watering hole attacks) and hacking of mailboxes and social media accounts.

The hackers also delivered malware using malicious documents set up to exploit the Microsoft Office flaw tracked as CVE-2017-0199. They leveraged automated scanning and exploitation tools such as Havij, sqlmap and Acunetix to find vulnerabilities in the targeted websites.

The threat actor used both its own and widely available malware and tools, including the TDTESS backdoor, the Matryoshka RAT, the Vminst lateral movement tool, the Cobalt Strike and Metasploit frameworks as well as Mimikatz tool.

Most of the infrastructure used by the group is in the U.S., Russia, and The Netherlands. Some of it has been in use for more than two years.

According to experts, CopyKittens has been active since at least 2013.

APT name	Regions attacked	Operation start
Attack against EirGrid	Ireland	2017

In early August, it was reported that undisclosed state-backed hackers had broken into the system of the Irish electric power transmission operator EirGrid. First, the hackers gained access to the Vodafone network used by EirGrid in the UK and then compromised routers used by the Irish operator in Wales and Northern Ireland. During at least 2 months the hackers went unnoticed while they gained access to the non-encrypted traffic of the power company. Attacks on the British and Irish power companies were recorded throughout the summer. There were no faults in power grid operation, but, according to experts, hackers could be interested in information about infrastructure and software.

Data leakage

GROUP IB

GLOBAL CYBER SECURITY COMPANY

- On September 8, 2017, the U.S. credit reporting agency Equifax said that hackers gained access to sensitive personal data for up to 143 million Americans, though the company's top management became aware of the intrusion on July 29. Equifax said the breach began in May and continued until it was discovered in late July. It said hackers exploited a "website application vulnerability" to obtain personal data including social security numbers, birth dates, addresses and, in some cases, driving license numbers. In addition, the hack compromised 209,000 people's credit card numbers and personal dispute details for another 182,000 people.
  Later, Equifax representatives reported that the leak occurred as a result of exploiting the CVE-2017-5638 vulnerability in Apache Struts. The vulnerability was patched in early March 2017. Due to the availability of exploits, attackers started exploiting the flaw almost immediately. In the spring, both Apache Struts developers and security experts warned about the need for urgent updates. However, the security team at Equifax failed to implement an effective patch, which led to serious consequences.
- Global tax and auditing firm Deloitte has confirmed the company suffered a cyber-attack that resulted in the theft of confidential information, including the private emails and documents of some of its clients. Attackers were able to penetrate the global mail server Deloitte under administrator login that, in theory, gave them privileged, unrestricted "access to all areas", including correspondence of Deloitte's 244,000 staff with their clients.
  An estimated 5 million emails were stored in the Azure cloud service and could have been accessed by hackers. Deloitte said the number of emails that were at risk was a fraction of this number but declined to elaborate.
  Besides emails, hackers also may have had potential access to "usernames, passwords, IP addresses, architectural diagrams for businesses and health information." Deloitte's internal investigation into the cyber incident is still ongoing.
- In late July, UniCredit Bank announced a data breach, which resulted in cybercriminals being able to steal data on 400,000 loan applicants. The breach was detected 10 months after the initial compromise, according to UniCredit. No data, such as passwords allowing access to customer accounts or allowing for unauthorised transactions, has been affected, whilst some other personal data and IBAN numbers might have been accessed.
- A critical API vulnerability in Instagram enabled attackers to access personal details of more than 6 million users. Hackers were offering them for sale at $10 apiece on an underground resource.
- Taringa, a Latin American social network confirmed a massive data breach that exposed nearly every record in its 28 million registered user base, including usernames, email addresses, and hashed passwords.
- Vevo, the joint venture between Universal Music Group, Sony Music Entertainment, Abu Dhabi Media, Warner Music Group, and Alphabet Inc. (Google's parent company) was hacked by the OurMine hacker group. This group usually does not seem to have ever gone beyond website defacement and hacking social media accounts, but this time OurMine leaked the huge trove of data, roughly 3.12 terabytes stolen from the servers of the company, on its website. Links to stolen information were active for a few hours, while the data were accessed by many people.
- WikiLeaks released another set of secret information about the CIA hacking tools named Achilles, Aeris and SeaPea that could be used to target Mac and Linux systems to steal information. A little earlier they published information about an Android application codenamed HighRise that is designed to redirect SMS messages to the C&C server. Following this, WikiLeaks revealed reports that showed that the CIA contractor Raytheon Blackbird Technologies, had been tasked to analyze advanced malware and TTPs used by the Chinese hacker groups Emissary Panda and Samurai Panda in the wild.
- Shadow Brokers started publishing hacking tools by subscription. The cost of the service is growing. The August dump contains the Undertake tool designed to collect data on Windows devices.
- IT security researchers discovered an unprotected database exposed online due to misconfiguration of CouchDB containing nearly 600,000 records belonging to Alaskan voters.

- Hackers accessed the corporate database of the U.S. Securities and Exchange Commission (SEC) and may have illegally profited by trading on the insider information stolen. The attack occurred in 2016 but it was only in August 2017 that the commission learned that hackers may have been able to perform illegal transactions using stolen data. The hackers exploited a software glitch in the test filing component of the system to gain access to non-public information. The SEC hosts large volumes of sensitive and confidential information that could be used for insider-trading or manipulating U.S. equity markets.

Hacktivism

GROUP IB

GLOBAL CYBER SECURITY COMPANY

In Q3 2017, hacktivists conducted over 2,600 attacks on more than 3,600 unique online resources. Over 2,400 attacks detected were “page replacement” (Defacement), more than 200 attacks were DDoS attacks (Denial of Service). In these attacks hacktivists targeted government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Thailand, Indonesia, Brazil, Vietnam, Peru, Mexico, Turkey, Myanmar, Russia, Italy, and India.

The table below contains information on the major hacktivists’ operations conducted in Q3 2017.

Operation name	**Regions attacked**	**Operation start**	**Types of attacks during the operation**
OpDomesticTerrorism	North America, Southern Africa, South America Western Europe, Eastern Europe	15.08.2017	DDoS, Deface
	The OpDomesticTerrorism operation was initiated by the Anonymous group following the violence in Charlottesville, USA. According to their announcement, they would fight alt-right and neo-Nazi groups, including the Ku Klux Klan.		
OpWhales, OpKillingBay	North America, Northern Europe, Southeast Asia		DDoS
	OpWhales and OpKillingBay operations were started by various hacker groups in order to attract public attention to animal protection issues. Originally they had targeted websites of entertainment theme parks, water parks and zoos to have further focused their attention on resources belonging to seafood suppliers and technology conglomerates which were considered to damage ecology. Currently, the hacktivists target websites of Japanese financial and government organizations, Norwegian government organizations, Icelandic seafood restaurants, and government organizations in Texas, the USA.		
OpRohingya	Myanmar	02.07.2013	DDoS, Deface, Data Leakage
	This operation was initiated by the Anonymous group. Their goal is to highlight the treatment of Myanmar's ethnic Rohingya people under the slogan “Stop the Rohingya genocide in Burma/Myanmar”.		
OpKKK	North America, Northern Europe	06.11.2015	DDoS
	During the operation hackers attacked websites related to neo-Nazis groups in the USA and Europe, including resources of organizations, which identify themselves with the Ku Klux Klan movement.		

Deface attacks: Additional Statistics

Group-IB specialists have summarized statistics of hacked websites (deface attacks), which is presented in charts below.

Chart 1 provides the breakdown of attacked resources by web servers used.

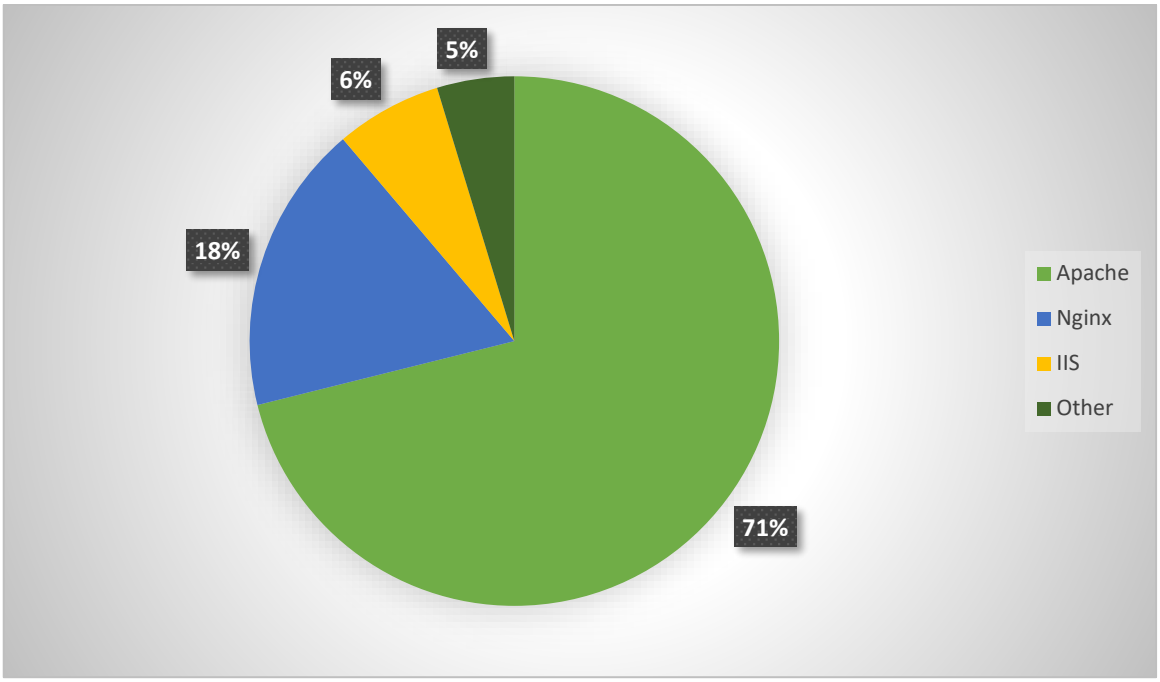


Chart 1 – Attacked resource ratio by web server

Chart 2 provides the breakdown of attacked resources deployed using IIS web servers. As seen from the chart, the most popular versions are 7.5 and 8.5. This can be explained by the fact that each version is released as a component of a Windows operating system. For example, version 7.5 was part of Windows 7 and Windows Server 2008, and version 8.5 was included in Windows 8.1 and Windows Server 2012 R2. The share of IIS 6.0 declined by 20% compared to the previous quarter. Following the high-profile ransomware attacks, users have started to update their server software more often.

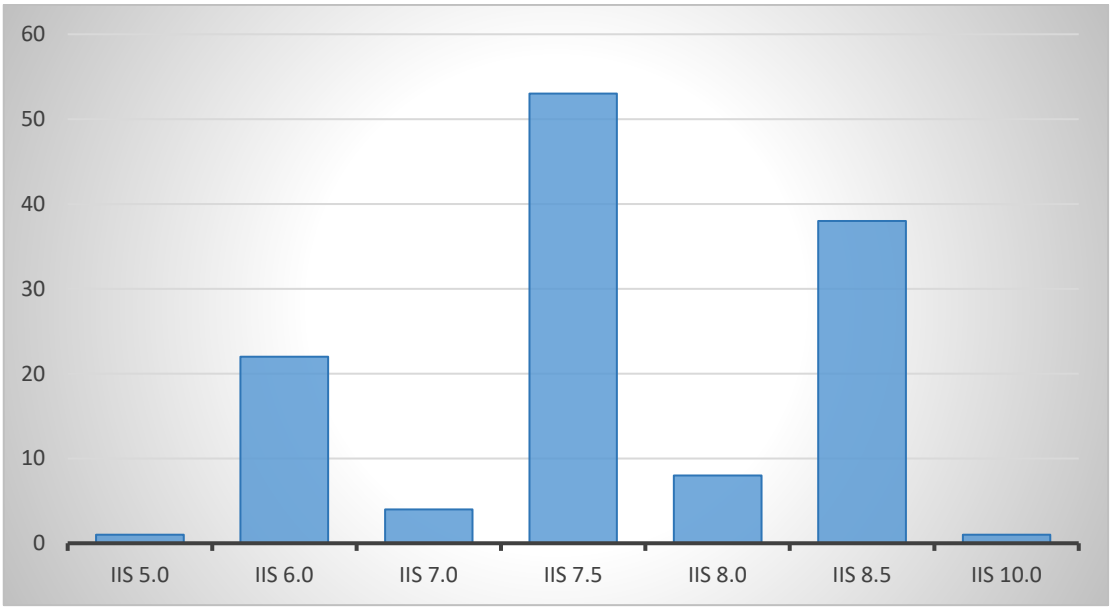


Chart 2 – Attacked resource ratio by IIS version installed

Over a third of all attacked resources were created based on content management systems (CMS). Chart 3 provides the breakdown of attacked resources by CMS used.

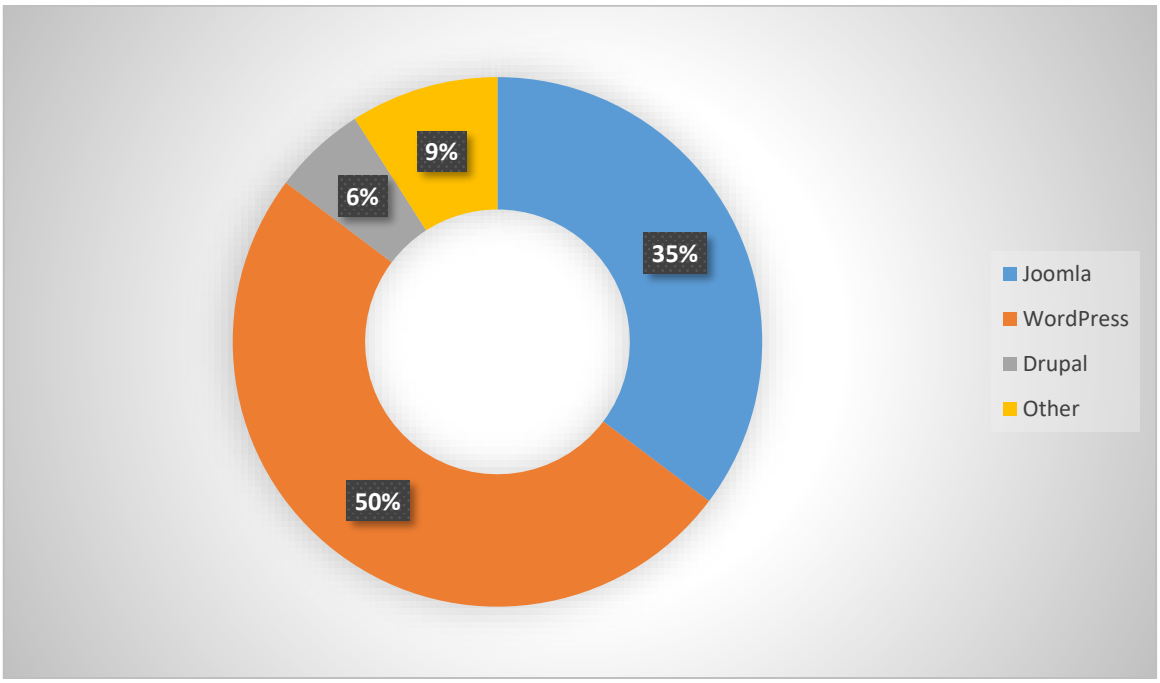


Chart 3 – Breakdown of attacked resources by CMS